DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Project Title:

DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Program: Naan Mudhalvan

Course : Cyber Security

Institution : KAYPEEYES COLLEGE OF ARTS & SCIENCE, KOTAGIRI (Bru5j)

GitHub Link:

https://github.com/karthikeyan857/NM-Cyber-Security-Project.git

Demo Video Link:

https://drive.google.com/file/d/1pltkNmyUGdgM538VIQ4hEpfvKmFLzTgD/view?usp=sharing

List of teammates

S.no	Name	Contact
1	KARTHIKEYAN.T	karthikeyant857@gmail.com

PROJECT DETAILS:

TITLE:

DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

INTRODUCTION:

The modern digital world, facilitated by cloud computing, remote working, and mobile devices, has outgrown traditional network-centric security models. These models are no longer capable of protecting critical information against modern threats, including those caused by weak authentication and compromised devices. This has led to a critical need to develop intelligent and adaptive security models.

This need is met by context-aware access control (CAAC), which evaluates various factors such as user identity, device security, location, and application before granting access. These factors are evaluated by the CAAC system, allowing it to make a decision regarding access, restriction, or denial of access.

The major objective of this project is to design and implement a context-aware access control system, which evaluates the above factors before enforcing a security action such as granting access, enforcing MFA, or denying access. This will reduce access attempts by unauthorized users and protect critical information while establishing a highly intelligent and adaptive security model.

ABSTRACT:

However, with the increased use of cloud services, mobile devices, and flexible work environments, the conventional network security model has become obsolete. Conventional access control models, which are based on fixed network boundaries and simple authentication schemes, are not sufficient for providing network security. In the contemporary business environment, the number of potential threats is constantly on the rise, which may come from devices, networks, or users. This has necessitated the need for an intelligent access control model that is based on a number of factors, rather than conventional authentication schemes.

This project, which is based on the design and application of context-aware access controls based on user identity, device posture, location, and application risk, aims to design a dynamic access control model that will provide enhanced security for a digital environment. The access control model will be based on a number of factors, including user identity, the security status of the devices being used, location, and the risk level of the application being used. Based on this, the system will generate a real-time risk score for every access request.

Accordingly, the system will make intelligent decisions based on the context, such as providing access.

The expected outcome of this project is a robust and flexible security model that reduces the risk of unauthorized access, protects sensitive organizational data, and minimizes the impact of credential compromise. At the same time, the system ensures a smooth and efficient user experience for trusted users operating in secure environments. By adopting a context-aware access control approach, organizations can establish a stronger security framework that supports safe and productive access to resources in today's highly dynamic and perimeter-less digital landscape.

Use Case Scenarios :

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA). ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

- User authenticated and authorized based on identity and group membership
- Direct micro-tunnel established specifically to the ERP application
- All other internal applications and network segments remain invisible and inaccessible

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

- Time-bound and role-specific access enforced
- Contractor restricted to a single application (Git repository)
- Lateral movement to adjacent systems completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents

A company VP needs to access a folder containing confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center while traveling internationally, using their company-managed tablet. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, executive group membership, and device posture (which is compliant). However, the geolocation (unusual foreign country) and the application risk (highly sensitive document repository) trigger an elevated risk score. The policy engine grants access to the SharePoint site, but enforces additional restrictions: download and print capabilities are disabled, and the session is monitored for unusual behavior (e.g., mass download attempts). An alert is also sent to the security team for high-risk executive login.

Output:

- User authenticated with MFA and device compliant, but flagged for unusual location
- Read-only access granted with download/print restrictions enforced
- Security team alerted to potential credential misuse or espionage attempt

Scenario 4: Remote Support Technician Access to Internal Tools

An IT support technician needs to access the corporate ServiceNow instance and a remote desktop tool to assist an employee. The technician connects from their home office using a company-managed desktop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (IT_Support), device posture (fully compliant), and connection type (home office, which is whitelisted for IT staff). Because the user, device, and location all meet the baseline, the policy engine grants direct micro-tunnel access to both ServiceNow and the specific remote desktop jump host used for employee support. The technician can perform their duties efficiently, but still has no access to finance systems, HR databases, or source code repositories.

Output:

- User authenticated and fully authorized based on trusted context
- Direct micro-tunnels established to ServiceNow and the remote desktop jump host
- Least-privilege access maintained; unrelated internal systems remain invisible

Scenario 5: High-Risk Application Access from a Low-Trust Location

A marketing coordinator needs to access the corporate Salesforce instance to update a campaign. The user connects from a coffee shop using their company-managed smartphone. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (Marketing_Salesforce_Users), device posture (managed and compliant), but flags the public Wi-Fi network as a high-risk connection. The policy engine determines that while the user and device are trusted, the network environment introduces unacceptable risk for direct access to a customer-facing CRM containing sensitive lead data. Instead of blocking access entirely, the user is routed through a secure ZPA browser isolation service, rendering the Salesforce session in a disposable container that prevents any data from persisting on the device or being exposed to the public network..

Output:

- User authenticated and device compliant, but network location deemed high-risk
- Access granted via browser isolation to prevent data leakage on public Wi-Fi
- Session is rendered in a secure container with copy/paste and download controls enforced

Stage – 1

Title: OWASP TO 10

Overview:

The OWASP Top 10 (2025) is a well-recognized list by the OWASP Foundation that identifies the most critical security risks present in modern web applications. This is an essential guideline for developers, security experts, and organizations to understand the security risks and implement security best practices for web applications. The OWASP Top 10: 2025 is a list of key security risks present in modern web applications, including broken access control, security misconfiguration, software supply chain issues, weak cryptography, injection attacks, insecure design, authentication issues, software and data integrity issues, logging and monitoring issues, and handling exceptions incorrectly. These security risks are the most common security issues faced by attackers to penetrate the web application and sensitive information. By identifying the security risks from the OWASP Top 10: 2025 list, organizations can implement security best practices and improve secure coding practices to prevent cyber attacks and security breaches from modern digital systems.

List of Vulnerability Table :

S.no	Vulnerability Name	CWE/CVE - No
1	Absolute Path Traversal	CWE-36
2	ASP.NET Misconfiguration: Password in Configuration File	CWE-13
3	Use of Unmaintained Third Party Components	CWE-1104
4	Cleartext Transmission of Sensitive Information	CWE-319
5	Improper Neutralization of Equivalent Special Elements	CWE-76
6	Plaintext Storage of a Password	CWE-256
7	Improper Authentication	CWE-287
8	Untrusted Search Path	CWE-426
9	Omission of Security-relevant Information	CWE-223
10	Unchecked Return Value	CWE-252

REPORT

Vulnerability Name:- Absolute Path Traversal

CWE/CVE : -CWE-36

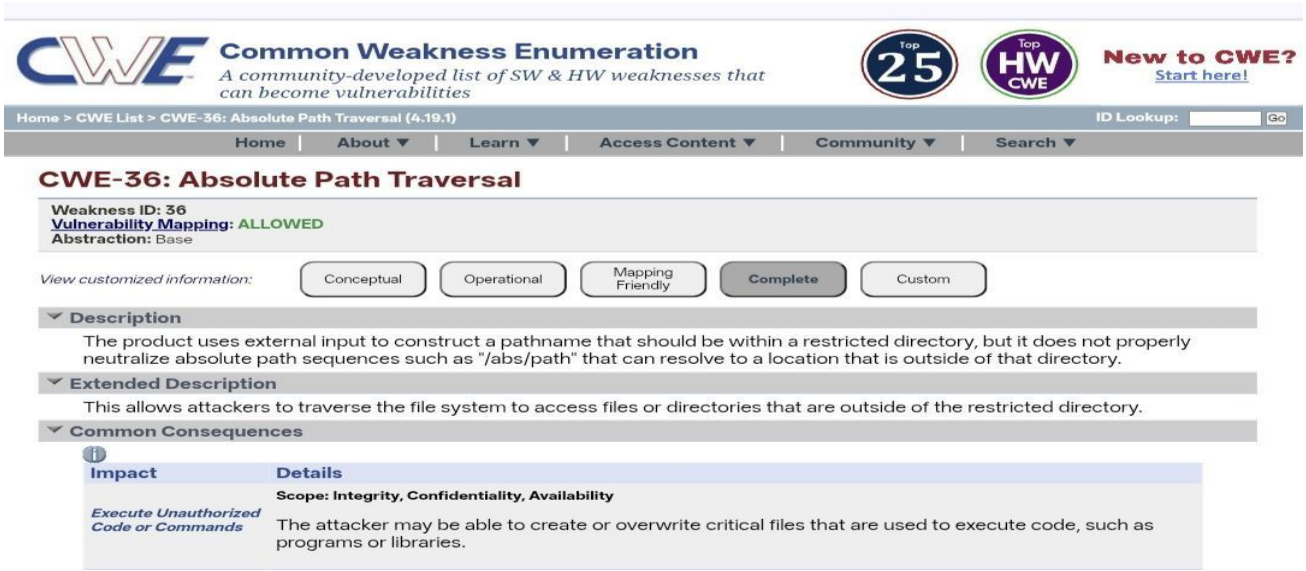
OWASP/SANS Category:-A01:2025 Broken Access Control

Description:-

The Absolute Path Traversal vulnerability allows an attacker to gain unauthorized access to files and directories outside the target directory of a web application. This happens when user input used in file path manipulation is not validated. By manipulating the path of a file, an attacker gains unauthorized access to critical files like system configuration files, source code of an application, and confidential user data.

Business Impact::-

Absolute Path Traversal is a critical issue, which, if exploited, may allow attackers to access sensitive data such as system configurations, source code for applications, or even sensitive business data. This may lead to data breaches, disclosure of internal data, system compromise, and loss of customer trust. It may even lead to financial loss, legal consequences, and harm to the organization's reputation.



Vulnerability Name:- ASP.NET Misconfiguration: Password in Configuration Fil**e**

CWE/CVE : CWE-13

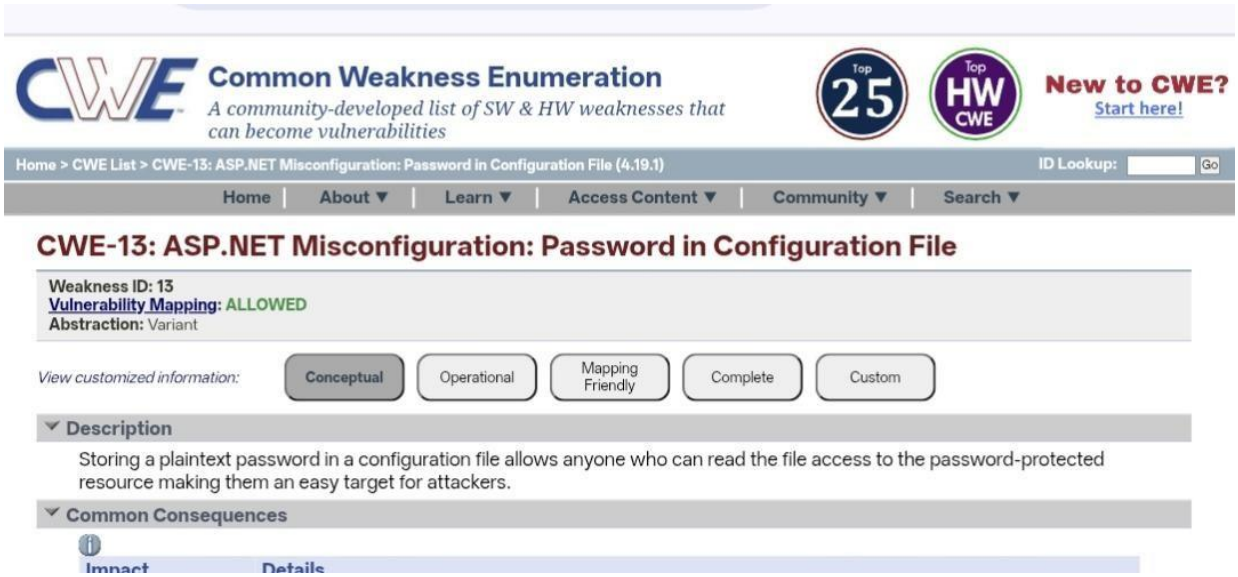
OWASP/SANS Category: A02:2025 - Security Misconfiguration

Description:-

This vulnerability occurs when sensitive information such as passwords, database credentials, or API keys are stored in plain text within ASP.NET configuration files (e.g., web.config). If these configuration files are not properly secured, attackers may gain access to them through misconfigured servers, source code exposure, or unauthorized file access. Once obtained, these credentials can be used to access databases, internal systems, or other critical services

Business Impact:

In addition, if passwords are exposed in configuration files, unauthorized access to critical systems and organizational data may be realized. An attacker may use these exposed passwords to gain unauthorized access to databases, alter application data, and gain deeper access to the internal network. This may cause damage to an organization in terms of financial losses, legal action against the organization, and damage to its reputation.



Vulnerability Name:-Use of Unmaintained Third Party Components

CWE/CVE : CWE-1104

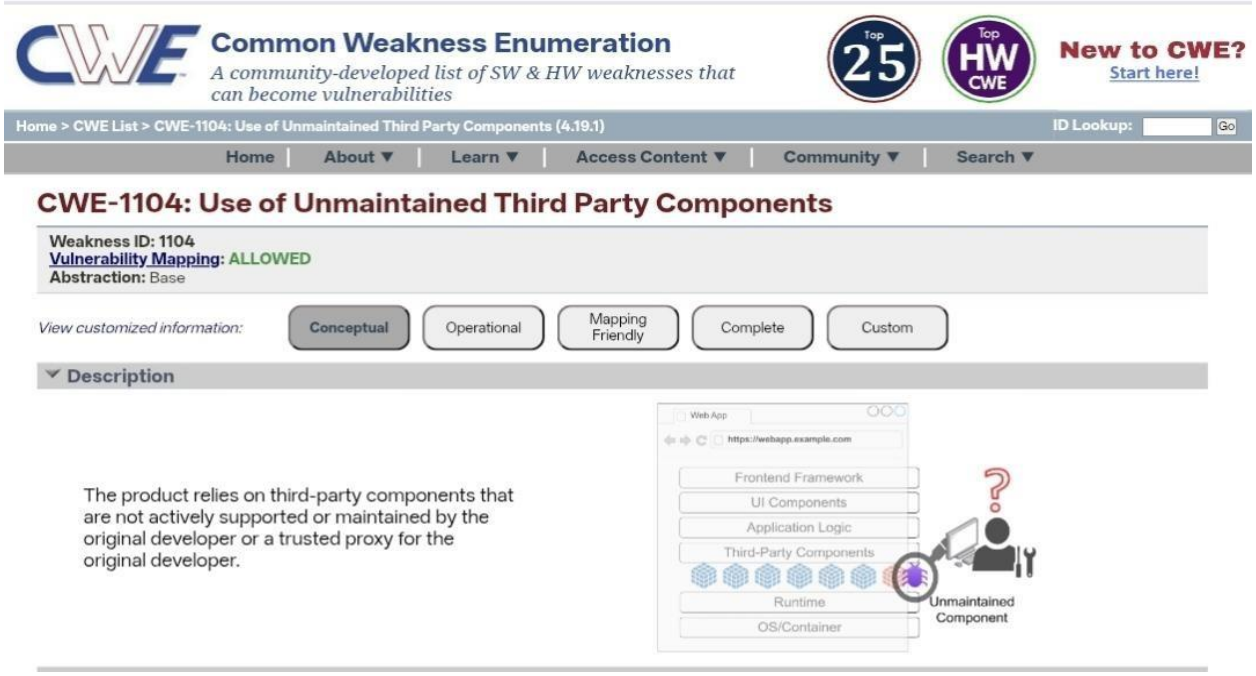
OWASP/SANS Category: A03:2025 - Software Supply Chain Failures

Description:-

This type of vulnerability occurs when the application under consideration is using third-party libraries or components that are no longer supported or updated by their developers. Such components may have known security vulnerabilities that are still open to exploitation. Since these components are not updated with security patches or fixes, the vulnerabilities that exist in these components may be exploited to compromise the application.

Business Impact:

Using unmaintained third-party components can expose the application to serious security risks, This includes unauthorized access, data breaches, and system compromise. Attackers may use known vulnerabilities of outdated system components to gain control of the system and/or unauthorized access to critical data. This may result in financial losses, disruptions to operations, legal consequences, and damage to an organization's reputation and customer loyalty.



Vulnerability Name:- Cleartext Transmission of Sensitive Information

CWE/CVE : CWE-319

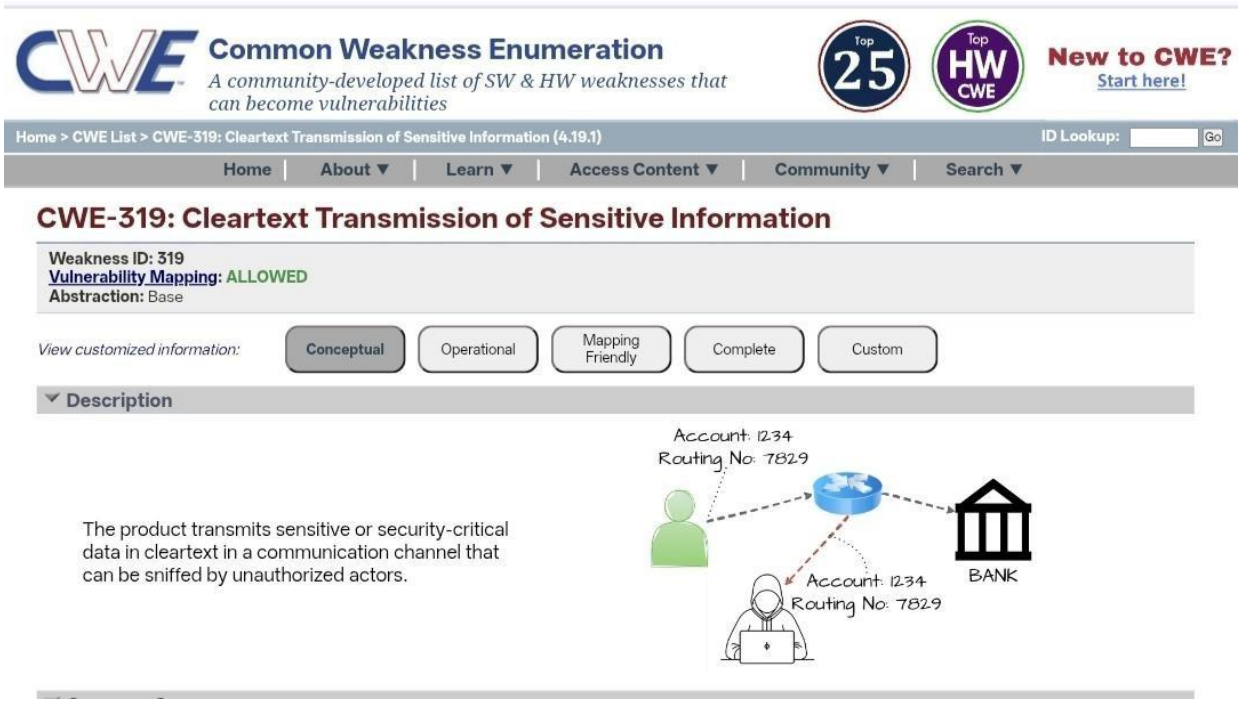
OWASP/SANS Category: A04:2025 - Cryptographic Failures

Description:-

This weakness occurs when confidential data like usernames, passwords, personal data, and financial details are being transmitted over a computer network without any form of encryption. This happens when an attacker intercepts and reads the data in cleartext by using techniques like network sniffing and man-in-the-middle attacks. This typically occurs when there is an improper implementation of secure communication protocols and/or encryption.

Business Impact:

Unauthorized access to confidential information, as well as breaches, can also be caused by the cleartext transmission of sensitive information. This can be used by attackers for other attacks or for identity theft, financial fraud, and other malicious purposes. This can cause financial loss, legal actions, and damage to the organization's reputation and customer trust.



Vulnerability Name:-Improper Neutralization of Equivalent Special Elements

CWE/CVE : CWE-76

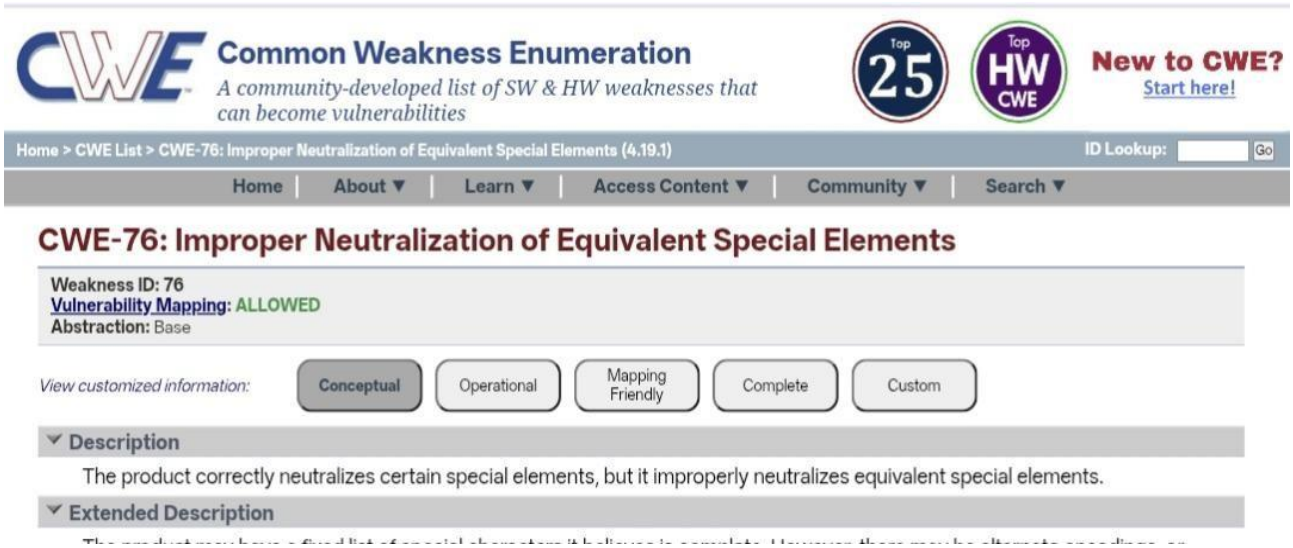
OWASP/SANS Category: A05:2025 - Injection

Description:-

This is where a web application is not properly validating or sanitizing special characters or elements in user input. This vulnerability is exploited by attackers who insert malicious code or unexpected input that is interpreted differently by the web application, which may cause security issues such as injection attacks or unauthorized activities. This is where attackers get to bypass the security mechanisms of the web application.

Business Impact:

If this weakness is abused, it could allow a hacker to access confidential information, modify the information of the application, or run unauthorized commands within the system. This could result in a loss of information, disruption of services, and compromise of critical systems. Therefore, organizations could suffer a loss of money, penalties, and damage to their reputation.



Vulnerability Name:-Plaintext Storage of a Password

CWE/CVE : CWE-256

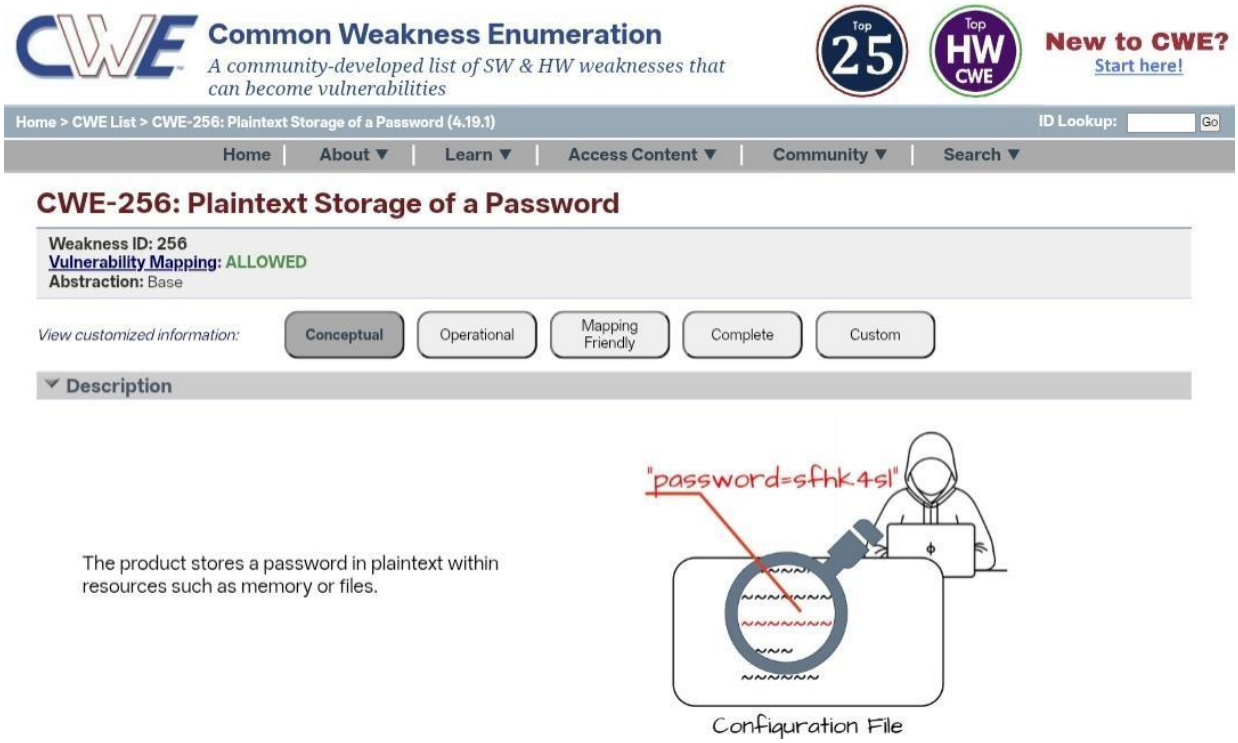
OWASP/SANS Category: A06:2025 - Insecure Design

Description:-

This weakness exists when an application fails to filter special characters or encoded information from the user. In this case, attackers can use other forms of the same character to evade the security filters and inject malicious information into the system. This weakness can be used by attackers to manipulate the application's behavior and perform unauthorized actions.

Business Impact:

Exploitation of this vulnerability can lead to unauthorized access of critical information, data manipulation, or execution of malicious commands within the application. This can lead to data breaches, service disruptions, financial losses, and damage to the reputation of the organization. Proper input validation and secure coding are critical in preventing such risks.



Vulnerability Name:-Improper Authentication

CWE/CVE : CWE-287

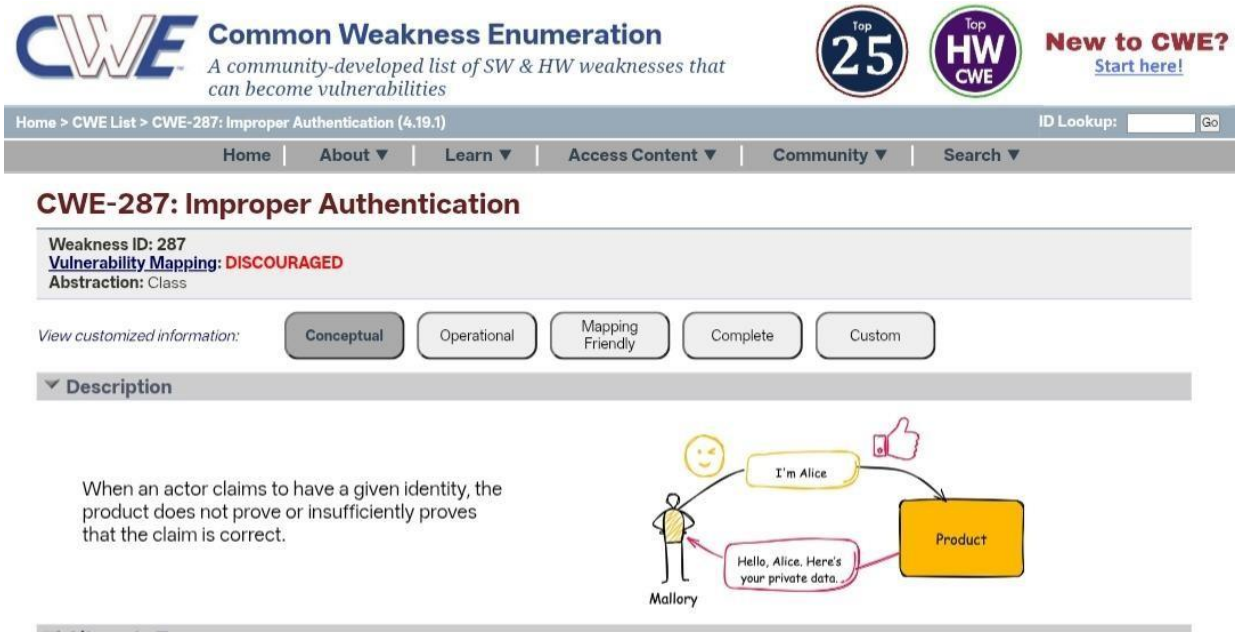
OWASP/SANS Category: A07:2025 - Authentication Failures

Description:-

Improper Authentication is when an application does not correctly verify the identity of a user before allowing access to system resources. This is a weakness in the system, which can occur because of weak authentication, weak management of sessions, or weak login controls. This can be exploited by an attacker, who can bypass authentication checks and obtain unauthorized access.

Business Impact:

If not properly addressed, this could allow an attacker access to sensitive data, unauthorized transactions, or even control over user accounts. This could, in turn, lead to data breaches, financial loss, service disruptions, and the misuse of organizational resources. Furthermore, this could also harm the overall reputation of the organization.



Vulnerability Name:- Untrusted Search Path

CWE/CVE : CWE-426

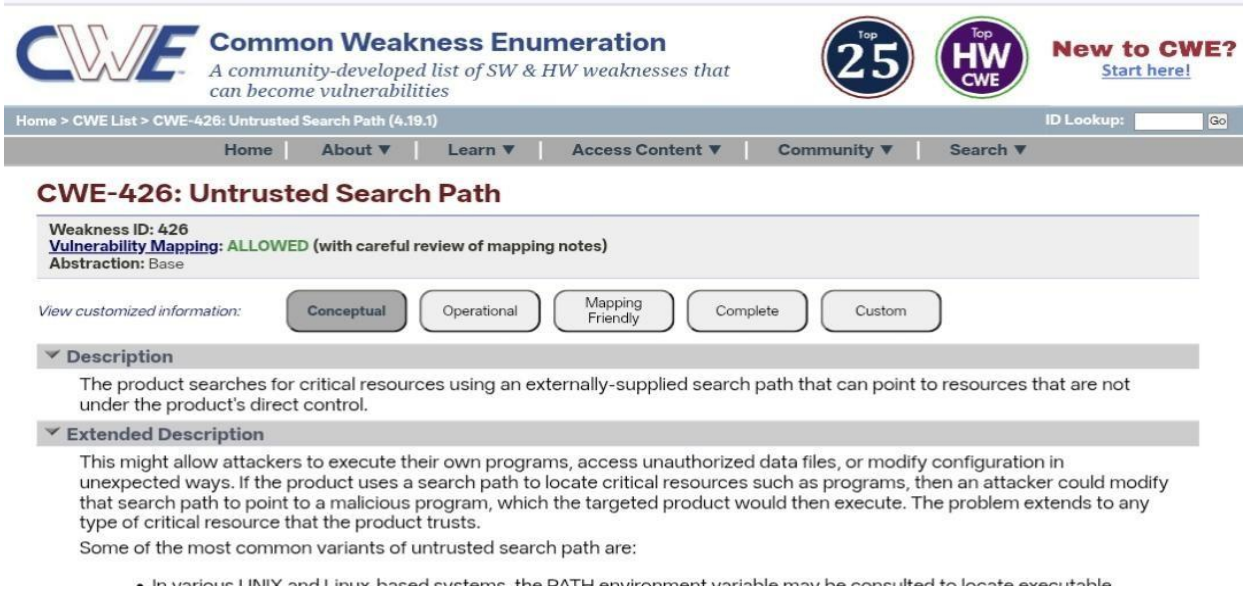
OWASP/SANS Category: A08:2025 - Software or Data Integrity Failures

Description:-

Untrusted Search Path is a vulnerability that occurs when an application loads external programs, libraries, or executable files from directories that are not trusted or properly secured. If the application does not specify a safe and fixed path for these files, attackers may place a malicious file in the search path. When the application runs, it may unknowingly execute the attacker's malicious file instead of the intended one.

Business Impact:

Exploitation of this vulnerability can allow attackers to execute malicious code within the system, potentially leading to system compromise, unauthorized access, or data manipulation. This can result in service disruption, data breaches, financial losses, and damage to the organization's reputation. Proper configuration and restricting execution paths can help prevent this risk.



Vulnerability Name:- Omission of Security-relevant Information

CWE/CVE : CWE-223

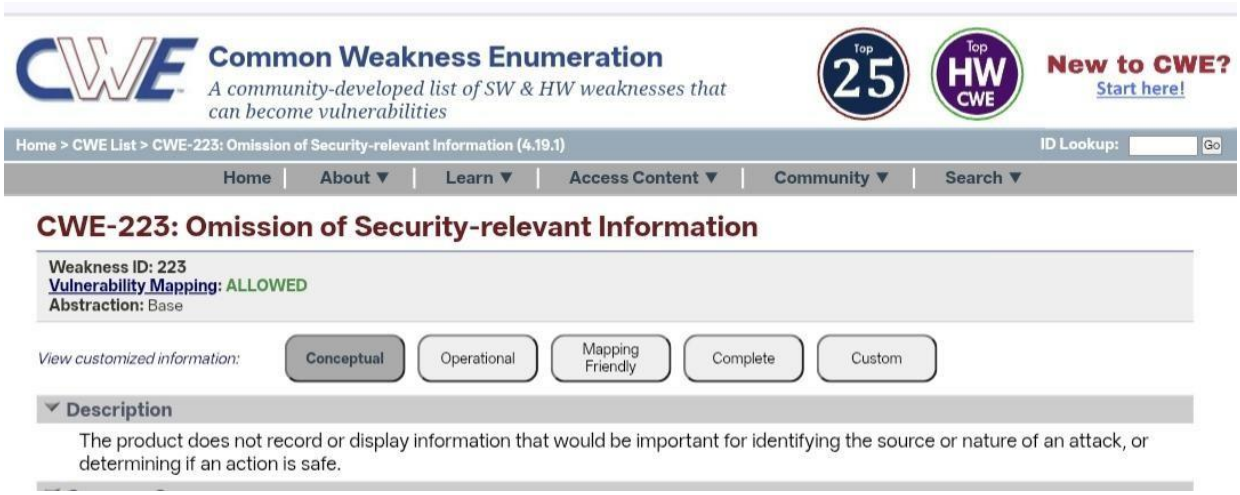
OWASP/SANS Category: A09:2025 - Security Logging and Alerting Failures

Description:-

Omission of Security-Relevant Information occurs when an application fails to record or provide important security-related details such as login attempts, access requests, errors, or suspicious activities. Without proper logging and monitoring, it becomes difficult to detect security incidents, investigate attacks, or respond to potential threats in a timely manner.

Business Impact:

If security-relevant information is not properly logged or monitored, organizations may be unable to identify unauthorized access, data breaches, or malicious activities within their systems. This can delay incident response, increase the impact of cyberattacks, and result in financial losses, regulatory penalties, and damage to the organization's reputation. Proper logging and monitoring practices are essential to maintain strong security visibility.



Vulnerability Name:-Unchecked Return Value

CWE/CVE : CWE-252

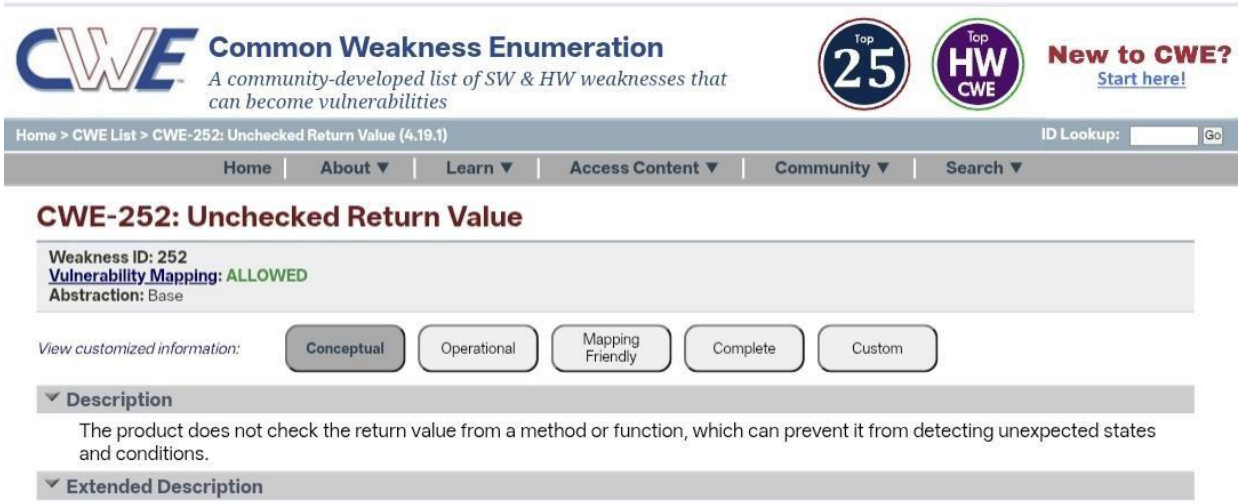
OWASP/SANS Category: A10:2025 - Mishandling of Exceptional Conditions

Description:-

Unchecked Return Value is a vulnerability that occurs when a program fails to verify the return value of a function or system call. Many functions return a value indicating whether an operation was successful or failed. If the application does not check these return values, it may continue execution even when an error has occurred. This can lead to unexpected behavior, security weaknesses, or system failures.

Business Impact:

Exploiting this vulnerability may allow attackers to trigger application errors, bypass security controls, or cause system instability. This can lead to data corruption, service disruptions, or unauthorized actions within the system. As a result, organizations may face operational issues, financial losses, and potential damage to their reputation.



Stage 2

Title: NESSUS SCAN

Overview:

A Nessus scan is a common method of performing a vulnerability assessment, which is done by utilizing a security scanning tool called Nessus, developed by Tenable. It is used for identifying security issues, vulnerabilities, and misconfigurations in computer systems, networks, and applications. Nessus scanning is used for scanning computers, servers, databases, and network devices, which helps in identifying potential security risks that could be exploited by attackers. It compares the configuration of the systems and software installed with a database of known security issues.

Nessus scanning involves different types of checks, such as identifying the presence of open ports, outdated software, missing security patches, weak configurations, and known security vulnerabilities, among others. After completing the scan, a report is generated that provides a detailed report on the identified vulnerabilities, which are classified based on the severity level, i.e., critical, high, medium, and low. This helps in addressing the vulnerabilities that could be exploited by attackers. Nessus scanning is an essential tool for maintaining a strong cybersecurity posture, which is critical for an organization's overall security.

Sl.No	Vulnerability Name	Severity	Plugins
1	Nessus SYN scanner	port scanner	11219
2	Device Type	General	54615
3	Traceroute Information	General	10287
4	TLS Supported Groups	General	277654
5	OS Fingerprints Detected	General	209654

Report:

Vulnerability name: Nessus SYN scanner

Severity:port scanner

Plugin: 11219

Description:

The Nessus SYN Scanner is a scanning technique used during vulnerability assessments to identify open ports and services running on a target system. It works by sending TCP SYN packets to specific ports and analyzing the responses from the target host. If the port responds with a SYN-ACK, it indicates that the port is open and actively accepting connections. While this technique is commonly used for legitimate security testing, if detected on a network it may indicate that an attacker or unauthorized user is attempting to scan the system to discover open ports and potential entry points.

Solution:

To reduce the risk associated with SYN scanning, organizations should implement strong network security measures. This includes configuring firewalls to block or limit unnecessary ports, using intrusion detection or prevention systems (IDS/IPS) to detect scanning activities, and restricting network access to trusted users. Regular monitoring of network traffic and applying proper access control policies can also help identify and prevent unauthorized scanning attempts.

Business Impact:

If attackers perform SYN scans successfully, they may discover open ports and vulnerable services within the network. This information can be used to launch further attacks such as exploitation of vulnerabilities, unauthorized access, or denial-of-service attacks. As a result, organizations may face data breaches, service disruptions, financial losses, and damage to their reputation. Implementing proper network monitoring and security controls is essential to mitigate this risk.

Vulnerability name: Device Type

Severity: General

Plugin: 54615

Description:

The Device Type finding in a Nessus scan identifies the type of device present on the network, such as a server, workstation, router, firewall, or printer. This information is gathered during the scanning process to understand the nature of the target system and the services it may provide. Although this is mainly informational, it can reveal useful details about the network infrastructure that could potentially be used by attackers during reconnaissance.

Solution:

To reduce the risk associated with device information disclosure, organizations should limit unnecessary exposure of system information. Network administrators should configure firewalls, disable unnecessary services, and restrict access to sensitive network details. Regular

vulnerability scanning and network monitoring should also be implemented to ensure that system information is not easily exposed to unauthorized users.

Business Impact:

If attackers obtain information about device types within a network, they may use this information to identify potential targets and plan more focused attacks. Knowing the type of device and its role in the network can help attackers exploit specific vulnerabilities related to that device. This may increase the risk of unauthorized access, system compromise, or disruption of critical services within the organization.

Vulnerability name: Traceroute Information

Severity: General

Plugin:10287

Description:

Traceroute Information is a finding that reveals the network path taken by data packets from the scanning system to the target host. During a Nessus scan, the traceroute process identifies intermediate network devices such as routers and gateways between the source and destination. This information helps administrators understand network routing and connectivity. However, if exposed, it may reveal details about the internal network structure and routing paths.

Solution:

To reduce the exposure of traceroute information, organizations should configure firewalls and routers to restrict unnecessary network diagnostic responses. Disabling or limiting ICMP responses and controlling network visibility can help prevent external users from discovering internal network routes. Regular network monitoring and proper configuration of security devices can also minimize the risk of information disclosure.

Business Impact:

If attackers obtain traceroute information, they may gain insights into the network architecture, including intermediate devices and network paths. This information can assist attackers in

mapping the network, identifying critical infrastructure components, and planning targeted attacks. As a result, it may increase the risk of network intrusion, system compromise, or disruption of network services within the organization.

Vulnerability name:TLS Supported Groups
Severity: General
Plugin:277654

Description:
TLS Supported Groups refers to the list of cryptographic groups (such as elliptic curve groups) that a server supports for establishing secure TLS connections. During a Nessus scan, this information is identified to determine whether the server supports strong or weak cryptographic groups. If weak or outdated groups are enabled, attackers may exploit them to weaken the encryption used during secure communication.

Solution:
Organizations should configure servers to support only strong and secure TLS cryptographic groups and disable weak or outdated ones. Regular updates to TLS configurations, applying security patches, and following recommended cryptographic standards can help strengthen secure communications. Security teams should also perform regular vulnerability scans to ensure that only modern and secure encryption groups are enabled.

Business Impact:
If weak TLS supported groups are enabled, attackers may exploit them to compromise the encryption used in secure communications. This could lead to interception or decryption of sensitive information transmitted between users and servers. As a result, organizations may face risks such as data breaches, exposure of confidential information, and loss of customer trust.

Vulnerability name:OS Fingerprints Detected

Severity: General

Plugin:209654

Description:

OS Fingerprints Detected is a finding from a Nessus scan indicating that the operating system of the target device can be identified through network responses and system behavior. During the scanning process, Nessus analyzes network packets, service responses, and system characteristics to determine the probable operating system running on the host. Although this information is useful for system administration and vulnerability assessment, it can also reveal system details to potential attackers.

Solution:

To reduce the risk of OS fingerprinting, organizations should implement proper network security controls. This includes configuring firewalls to limit unnecessary responses, disabling unused services, and using intrusion detection or prevention systems (IDS/IPS) to detect scanning activities. Regular patching and system hardening can also help minimize identifiable system characteristics.

Business Impact:

If attackers can identify the operating system of a target system, they can use this information to search for specific vulnerabilities related to that OS. This may allow them to launch targeted attacks, exploit known weaknesses, or gain unauthorized access to the system. As a result, organizations may face security breaches, service disruptions, or compromise of critical systems**.**

Stage 3

Title: Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Overview

In the contemporary digital environment, organizations are increasingly relying on cloud computing, mobile devices, and virtual work systems in order to carry on their day-to-day activities. However, this has also brought forth new security risks for organizations. Traditionally, security has been based on a network boundary where all users inside the network are assumed to be trusted users. However, this has become an ineffective model for organizations, given that employees are accessing systems from different devices and different locations.

Therefore, organizations are increasingly adopting advanced security models that ensure that all access requests are authenticated prior to providing access to sensitive resources. One such model is context-aware access control, which considers different factors related to the user and the environment. This is different from the traditional model, which is based on usernames and passwords, since this model considers different factors such as the identity of the user, the security level of the device being used, the location of the user, and the risk level of the application being used.

Identity

One of the most important aspects in access control systems is the concept of identity, which can be defined as the process of verifying and identifying the user who wants to access a given application, network, or resource. Therefore, the process of identity verification ensures that authorized individuals are able to access sensitive information within an organization.

In context-aware access control systems, identity verification does not end with the process of verifying a username and password for a given user. Other identity attributes, such as the role played by a given user, the job function of a given user, department, and permission, are also taken into consideration in context-aware access control systems. For example, the identity attributes of a person with administrative privileges may be different from a person with normal employee privileges.

In contemporary identity systems, multi-factor authentication (MFA) can be used as an additional layer of security in identity verification systems, where a user must be verified with multiple factors, for example, a password and a code sent to a given user for the purposes of verifying his or her identity in a given system.

Device Posture

The term "device posture" is used to refer to the overall security condition or health of the device from which an individual is seeking access. This is particularly important because, for instance, an individual might be using different devices such as a laptop, smartphone, or even a tablet. It is, therefore, important to ensure that the device being used is secure enough for use within an organization.

The process of evaluating different aspects of a device, such as whether it is updated, whether it is using antivirus, whether it is encrypted, and whether it is managed by the IT department, is known as a "device posture check." This helps in evaluating whether a device is secure enough for use. For instance, a company-managed laptop might be secure enough for use, but a personal device might be considered a risk.

Application Risk

Different applications in an organization may have different levels of sensitivity and importance. Some applications may be dealing with general information, while others may be dealing with sensitive information related to business, finance, or individuals. Therefore, the level of security for different applications should be different based on the risk level of the application.

Risk assessment for different applications in the system can be used to evaluate the potential risk or impact in case a particular application in the system is attacked or accessed in an unauthorized manner. In case of high-risk applications, which may be related to financial information, administrative information, or sensitive information, the access control system can be set in a way that ensures strict security conditions are met.

However, in case of low-risk applications, the system can be set in a way that ensures easy access for authorized individuals. Therefore, risk assessment for different applications in the system ensures that security conditions are met based on the level of information accessed in the system.

Context-Aware Access

The concept of context-aware access is a new security model, which considers several contextual inputs before providing access to any applications or data. It does not make static decisions based on login credentials. It considers different contextual inputs, such as user identity, device, location, time of access, and risk level of an application, before making any decision regarding access. The system considers all these contextual inputs and makes dynamic decisions regarding access in real time. For instance, if an employee logs in from a trusted device within the company's network, it may allow access to different applications seamlessly. On the other hand, if the same employee tries to access a critical system from an unknown device at an unknown location, it may deny access or ask for additional authentication. This is a great improvement in security for any organization, as it can prevent unauthorized access and different types of cyber attacks. At the same time, it provides a better experience for users. The concept of context-aware access control can be implemented for a secure and efficient working environment.

Conclusion:

Stage 1:

In conclusion, it is evident that testing of web applications is an integral part of ensuring the security, functionality, and reliability of web-based applications. This is because it entails a thorough evaluation of different aspects of the application, including user interface, functionality, performance, and security. This not only ensures the quality of the web-based applications but also ensures their robustness in the face of possible threats and challenges. This is particularly significant in an era where we are increasingly dependent on different online services and applications in our daily lives.

Stage 2:

The Nessus report for the particular website has provided significant security insights. It has identified vulnerabilities present in the website, categorized based on their severity. Particular attention is given to critical and high-severity vulnerabilities. Recommendations for addressing these vulnerabilities include implementing patches and reconfigurations to improve the security of the website. Particular attention is given to those vulnerabilities that can be addressed to have maximum impact. Industry standards and best practices have been considered to ensure that they comply with guidelines set by industry leaders and experts. This ensures that they adhere to guidelines set by OWASP. The report highlights the importance of continuous monitoring and updates to ensure maximum vigilance against potential and evolving threats. Thus, an overview of the website's security status is provided by the Nessus report.

Stage 3:

The introduction of ZPA is a significant change from a weak network-centric security paradigm to a strong identity-centric Zero Trust security paradigm. By enforcing least privileged access and making private applications invisible to the internet, this project eliminates the risks associated with lateral movement attacks and network-based attacks. This solution not only enhances the security posture of the organization against emerging cyber threats but also provides users with a high-performance user experience for a distributed workforce. Moreover, the decoupling of access from the network makes IT management simpler, reduces reliance on legacy VPNs, and provides detailed visibility into user-application interactions. This project lays the foundation for a future-proofed security paradigm for digital transformation.

Future Scope:

Stage 1: future scope of web application testing

The future scope of web application testing is bright, and it is expected to grow at a fast pace because of the increasing growth of the internet and web-based applications.

The following are some of the aspects of the future scope of web application testing:

- Increased Demand for Web Applications: As more businesses are moving towards the internet, the demand for web applications is increasing. This, in turn, will increase the demand for testing these web applications.
- Usage of Advanced Technologies: The complexity of web applications is increasing, and many technologies like AI, IoT, etc., are being integrated into these applications. Testing these cutting-edge technologies will require more expertise.
- Security of Web Applications: As more and more data is being breached, security testing of web applications is going to be more critical.
- Mobile Testing and Cross Browser Testing: As more and more people are using mobile devices, testing of web applications for mobile devices is going to be more critical.
- Performance Testing of Web Applications: As users are demanding more from web applications, performance testing is going to be more critical.

Stage 2: future scope of the testing process you understood.

The future scope of the web application testing process, especially with respect to the identification of vulnerabilities, is extremely bright due to the ever-increasing growth rate of digital platforms, the growing importance of cybersecurity, and the dynamic nature of the threat landscape. Following are some of the prominent aspects that reflect the prospective scope of web application testing for the identification of vulnerabilities:

- AI-Driven Testing: The incorporation of artificial intelligence (AI) and machine learning (ML) in web application testing tools is going to revolutionize the web application testing process for the identification of vulnerabilities. AI has the ability to rapidly process a huge amount of data to identify vulnerabilities that may otherwise remain undiscovered.
- IoT and Mobile App Testing: With the advent of Internet of Things (IoT) products and the growing usage of mobile applications, the scope of web application testing is going to expand to cover these areas as well. The security of IoT products and their interfaces is going to become extremely important.

Stage 3: future scope of Aware Access Control

With the successful implementation of ZPA, the path is now paved for further growth and evolution for the security infrastructure. Various avenues can be explored for further growth and maturation of the security infrastructure for the organization:

- Integration with Zscaler Internet Access (ZIA): Integration of Private Access (ZPA) with Internet Access (ZIA), providing a unified Secure Access Service Edge (SASE) solution for the organization.
- Advanced Device Posture Checking: In addition to basic compliance checking, the ability to incorporate risk score information from EDR tools to block access from compromised devices.
- Privileged Remote Access: Extending the capabilities of ZPA for third-party vendors and contractors to provide secure access to specific critical infrastructure for specific periods of time.
- IoT/OT Segmentation: Extending the capabilities of the solution for Internet of Things (IoT) and Operational Technology (OT) devices to only allow them to communicate with specific servers.
- AI-Driven Anomaly Detection: Using the logs from the ZPA solution to perform anomaly detection using machine learning to detect unusual user behavior, such as accessing an application outside their normal working hours from an unusual location.

Topics Explored:

1. Owasp top 10
2. Scanning
3. Vulnerability
4. Awareness
5. Identity

Tools Explored:

1. Nessus Scanner
2. Owasp
3. https://testphp.vulnweb.com/